悪性SIMアプレットによる通信チャネル占有攻撃の脅威評価*

迫本 澪[1,a)]　渡邉 龍星[1,b)]　古橋 俊輝[2,3,c)]　森 達哉[1,4,5,d)]

概要：IoT や M2M 機器の普及を背景に，SIM アプレット領域分割技術により第三者によるアプレット開発が自由化しつつある．SIM アプレットは，耐タンパ性を備えた SIM カード上で動作し，鍵管理や認証などの機密処理を担うアプリケーションである．開発効率化のためのライブラリ需要の高まりが見込まれ，その供給経路はサプライチェーン攻撃の新たな侵入口となり得る．しかし既存研究は Java Card OS やプラットフォームの実装脆弱性が中心で，サプライチェーンを介して混入し正規処理を装うコードがもたらす脅威は十分に検討されていない．こうした脅威のうち資源占有型については，先行研究でメモリを対象とした占有攻撃が示されている．本研究では，ネットワーク資源へ拡張し，アプレットが端末を介して TCP/UDP 通信を行う Bearer Independent Protocol (BIP) チャネルを標的とした資源枯渇型 DoS「通信チャネル占有攻撃」を提案する．PoC を実装し，複数の実機で実現可能性と端末依存性を評価した．その結果，チャネルは同一 SIM カード上で共有され，同時に開けるチャネル数の上限は端末により異なるが，悪性アプレットが全チャネルを占有することで正規アプレットの通信を妨害できることを確認した．以上より，先行研究のメモリ占有に続き，ネットワーク資源の占有が SIM アプレットの新たな脅威となることを示し，その防御指針を整理した．

キーワード：SIM アプレット，BIP チャネル，サプライチェーン攻撃，IoT セキュリティ

Threat Assessment of Communication Channel Exhaustion Attacks via Malicious SIM Applets

Rei Sakomoto[1,a)]　Ryusei Watanabe[1,b)]　Shunki Furuhashi[2,3,c)]　Tatsuya Mori[1,4,5,d)]

Abstract: Driven by the spread of IoT and M2M devices, SIM applet partitioning technology is opening SIM applet development to third parties. A SIM applet is an application that runs on a tamper-resistant SIM card and handles sensitive processing such as key management and authentication. The resulting demand for development libraries creates a new entry point for supply chain attacks. Existing studies focus on implementation vulnerabilities of the Java Card OS and platform, leaving largely unexamined the threat of supply-chain-injected code that disguises itself as legitimate processing; for this resource-occupation type, prior work has shown only a memory exhaustion attack. We extend the target to network resources and propose a communication channel exhaustion attack, a resource exhaustion DoS that occupies the Bearer Independent Protocol (BIP) channels an applet uses for TCP/UDP communication via the device. We implement a PoC and evaluate it on multiple real devices. The BIP channels are shared on the same SIM card, and although the simultaneous-channel limit differs by device, a malicious applet can block legitimate applets by occupying all channels. Following the memory exhaustion of prior work, these results show that network resource occupation is a new threat to SIM applets, for which we organize defensive guidelines.

Keywords: SIM applet, BIP channel, supply chain attack, IoT security

© 2026 Information Processing Society of Japan

This paper is work in progress and not peer-reviewed.

1. はじめに

スマートフォンから産業用 IoT まで，今日の通信機器の多くは SIM カードを内蔵する．SIM カードは耐タンパ性を備え，加入者情報や鍵を安全に保持するセキュリティ基盤である．IoT 機器は 2030 年には約 390 億台に達すると見込まれ [2]，その通信基盤として，SIM の利用はスマートフォンから IoT や M2M 機器へと広がっている．この普及を背景に，専用の HSM や TPM を追加せずとも，すでに搭載された SIM を認証や鍵管理の土台として用いる動きが広がっている [3]．この SIM の内側では，Java Card を基盤とする SIM アプレットが，鍵の保管や認証，決済補助などの機密処理を担う．アプレットの搭載に必要な鍵は，従来，通信事業者のみが管理していた．この状況を変えたのがアプレット領域分割技術であり，アプレット領域の鍵管理を一般の企業が担えるようになったことで，第三者による SIM アプレットの開発と展開が現実になりつつある [4]．しかし，通信事業者に限られていたアプレットの導入が第三者へ開かれることは，信頼の基点である SIM の内側に，これまで想定されなかった攻撃の入り口を生み出す．

第三者開発の広がりは，開発を効率化するライブラリへの需要を生み，その一部はオープンソースソフトウェア（OSS）として流通すると見込まれる．OSS は，ソフトウェアを取り込む多数の開発者や製品へ一斉に影響を及ぼすサプライチェーン攻撃の格好の標的である．攻撃者が OSS のライブラリに悪性コードを潜ませ，正規の更新プロセスを通じて配布すれば，被害は気づかれないまま広範囲に及ぶ．OSS へ悪性コードが混入する事例は，複数のエコシステムで発生している．圧縮ユーティリティの XZ Utils には巧妙なバックドアが仕込まれ [5]，npm の event-stream パッケージにはメンテナ権限の移譲を悪用して悪性コードが持ち込まれた [6]．SIM アプレットの開発環境が第三者に開かれた現在，同じ構図が SIM アプレットにも持ち込まれうる．正規の開発と配布プロセスを通じて悪性アプレットが SIM に搭載されると，耐タンパ性に守られた内側から不正に振る舞うことになる．

SIM セキュリティに関する既存研究は，Java Card OS の実装脆弱性や，暗号，通信プロトコルの安全性評価に主眼を置いてきた．実運用の SIM に対しても，事業者があらかじめ搭載していた SIM 上のアプリケーションである S@T Browser が，認証を経ない OTA（Over-the-Air）SMS のコマンドを実行してしまう仕様を突かれ，利用者に気づかれずに位置情報などが窃取される Simjacker が報告されている [7]．これらは，プラットフォームや OS の欠陥，あるいは事業者が搭載したアプリケーションの脆弱性を対象としており，正規の機能のみを濫用するアプリケーションレベルの脅威は見落とされてきた．この空白のうち，先行研究はメモリを標的とした占有攻撃を示し，正規アプレットの処理を妨げられる仕様を明らかにした [1]．しかし，SIM アプレットが端末を介して TCP/UDP 通信を行うために用いる Bearer Independent Protocol (BIP) チャネル [8] のようなネットワーク資源が占有される攻撃は，検討されていない．ネットワーク資源が枯渇すれば，SIM を起点とする通信が止まり，被害はメモリ占有よりも直接的になりうる．

本研究では，占有の対象をメモリからネットワーク資源へ拡張した通信チャネル占有攻撃を提案する．悪性アプレットは，端末の BIP チャネルを確保可能な上限まで開いて保持し，正規アプレットが新たなチャネルを開けない状態を作り出す．この攻撃は標準化された Proactive Command のみを用い，Java Card OS の脆弱性や物理攻撃に依存しないため，特定のカードや端末の欠陥を必要としない．提案手法の実現可能性を，PoC 実装，モデム系統の異なる 2 機種の実機によって評価した．その結果，いずれの端末でも悪性アプレットが最大数のチャネルを占有することで正規アプレットの通信を遮断し，攻撃が成立した．同時に開けるチャネル数は端末によって異なったが，その差は攻撃の成否を左右せず，本攻撃が端末に依存しない汎用的な脅威であることを示した．あわせて，チャネルの状態がアプレット間で共有されるという攻撃の前提を実機で確認し，検知と緩和のための防御およびその限界を整理した．

本研究の貢献は次のとおりである．

- ネットワーク資源である BIP チャネルを標的とした資源枯渇型 DoS（通信チャネル占有攻撃）を提案する．
- BIP チャネル資源がアプレット間で共有されるという攻撃の前提を実機で明らかにする．
- PoC を実装し，モデム系統の異なる 2 機種で攻撃が成立すること，および端末差が成否を左右しないことを示す．
- チャネル状態の監視，強制 Close，監視用チャネルの事前確保，ロード時のトークン検証などの防御手法を検討し，その有効性と限界を示す．

本研究は，先行研究のメモリ占有に続き，悪性 SIM アプレットによる資源占有型攻撃の新たな攻撃面を実証した点

*本研究は著者らの過去の発表 [1]（信学技報，2025）を発展させ，占有の対象を揮発性メモリからネットワーク資源である BIP チャネルへ拡張し，通信チャネル占有攻撃の実現可能性の評価と防御手法の検討を新たに実施し，その結果を報告するものである．

[1] 早稲田大学
[2] 株式会社エヌ・エフ・ラボラトリーズ
[3] 筑波大学
[4] NICT
[5] 理研 AIP
[a)] rei.sakomoto@nsl.cs.waseda.ac.jp
[b)] ryusei.watanabe@nsl.cs.waseda.ac.jp
[c)] s2620567@u.tsukuba.ac.jp
[d)] mori@nsl.cs.waseda.ac.jp

© 2026 Information Processing Society of Japan

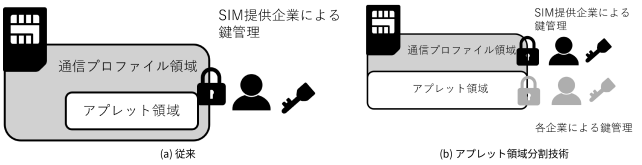


図 1 SIM の鍵管理．(a) 従来，(b) アプレット領域分割技術

に価値がある．

以降，第 2 章で関連研究，第 3 章で脅威モデル，第 4 章で実装と評価，第 5 章で防御手法，第 6 章で議論を述べ，第 7 章で結論を述べる．

2. 関連研究

2.1 SIM カードと SIM アプレット

SIM アプレットは，SIM カード上で Java Card を基盤に動作し，耐タンパ性を活かして鍵の保管や認証，署名などの機密処理を担う小規模なアプリケーションである．ただし Java Card の制約により，利用できるメモリや演算性能は限られる．

BIP と CAT．SIM アプレットが端末を介して外部と通信するための仕組みが，Bearer Independent Protocol（BIP）と Card Application Toolkit（CAT）である [8]．CAT は，SIM アプレットが端末に対して能動的に処理を要求する Proactive Command の枠組みを定める．BIP はそのうち `OPEN CHANNEL` や `SEND DATA` などのコマンドを通じて，端末のネットワーク機能を用いた TCP/UDP 通信を SIM アプレットに提供する．この際 SIM アプレットが確保する通信路を BIP チャネルと呼ぶ．BIP チャネルは端末側の資源であり，同時に確保できる数には上限があるため，本研究で扱う通信チャネル占有攻撃の前提となる．

アプレット領域分割技術．従来，SIM アプレットのインストールに必要な鍵は通信事業者が管理しており，第三者がアプレットを展開することは困難であった（図 1(a)）．これに対しアプレット領域分割技術は，通信に用いる通信プロファイル領域と，任意のアプリケーションを扱うアプレット領域を分離し，アプレット領域を利用者側が自主的に管理して利用できる構成を実現する [4]（図 1(b)）．この技術により第三者による SIM アプレットの開発と展開が現実的になり，決済端末のように機微情報を SIM 内で処理する応用も登場している．

2.2 SIM とセキュリティ

防御手法に関する既存研究．Zhao らは SecureSIM を提案し，SIM/eSIM における認証とアクセス制御を再設計することで，各アプレットや SIM 外のエンティティに対する細粒度のアクセス制御を実現する手法を示している [9]．また，SIM スワップ攻撃への対策を考慮した効率的な機器変更手法も提案されている [10]．これらは，SIM の正規の機能や運用を保護し，強化する方向の研究である．

攻撃手法に関する既存研究．一方，SIM 上で動作する Java Card OS を標的とする攻撃手法が数多く報告されている．Barbu らは，Java Card 3.0 に対するフォールト攻撃と論理攻撃を組み合わせた複合攻撃 [11]，オペランドスタックへのフォールト攻撃 [12]，および組み込みの盗聴攻撃 [13] を示した．Lancia は，位置に依存しないフォールト注入による複合攻撃を提案し [14]，Bouffard らは，Java Card プラットフォームの実装を悪用して，正規のアプレットを敵対的なアプリケーションへ変換しうるかを評価している [15]．これらはいずれも，プラットフォームや OS の実装レベルの脆弱性を対象とする．

研究のギャップ．既存の研究は，Java Card OS の実装脆弱性に焦点を当てており，アプレット領域分割技術による第三者開発の広がりを踏まえた，アプリケーションレベルの悪性コードによる脅威は十分に検討されていない．本研究は，このギャップに対し，正規の機能のみを濫用するアプリケーションレベルの攻撃を扱う点で既存研究と異なる．

2.3 メモリ占有攻撃

資源占有型の脅威として，先行研究は SIM アプレットによるメモリ占有攻撃を提案している [1]．この研究は，SIM カード上の揮発性メモリが複数のアプレット間で共有される点を悪用する．あらかじめ設定した時間トリガーで悪性 SIM アプレットが起動し，利用可能な揮発性メモリ（Transient メモリ）を上限まで確保する．揮発性メモリは一定時間で解放されるため，悪性アプレットは定期的に再確保することで占有を継続する．その結果，正規アプレットは処理に必要なメモリを確保できず，暗号処理などの実行が妨げられる．メモリの解放条件は，全アプレットが一定時間動作しないこと，またはカードのリセットに限られ，占有の継続は容易である．

本研究は，この占有の対象を揮発性メモリからネットワーク資源である BIP チャネルへ拡張し，同種の資源枯渇型 DoS が成立するかを検証する．

3. 脅威モデル

本章では，悪性 SIM アプレットによる通信チャネル占有攻撃の脅威モデルを示す．

3.1 攻撃概要と攻撃者モデル

攻撃目標．攻撃者の目標は，同一 SIM カード上の正規アプレットのネットワーク通信を妨害することとする．悪性アプレットが端末の BIP チャネルを上限まで `OPEN CHANNEL` し，`CLOSE` せずに保持することで，共有資源であるチャネルを枯渇させる．その結果，正規アプレットは新たなチャネルを確保できず，通信が不能となる．この攻撃は，CPU やメモリではなくネットワーク資源を標的とする資源枯渇

© 2026 Information Processing Society of Japan

型の DoS である．

攻撃成立要件．本攻撃は，攻撃者がサプライチェーンを介して悪性アプレットを対象の SIM へ導入できること，および BIP チャネルが複数のアプレット間で共有される限られた資源であること，の二つを前提として成立する．悪性アプレットは，ETSI TS 102 223 [8] で標準化された Proactive Command（`TIMER MANAGEMENT` や `OPEN CHANNEL` など）のみを用い，正規のアプレットに許可される操作範囲内で動作する．特別な権限や Java Card OS の実装脆弱性，耐タンパ性の突破，物理的なサイドチャネルは一切必要としない．この点で，OS やプラットフォーム実装の欠陥に依存する既存研究（ 2.2 節）とは異なり，本攻撃が前提とするのは特定製品の欠陥ではなく，BIP チャネルが複数アプレット間で共有される有限資源であるという標準機構に内在する性質である．そのため，仕様に準拠した幅広い SIM と端末に適用しうる．実際に，モデム系統の異なる複数端末でこの前提が成り立ち，攻撃が成立することを第 4 章で示す．

検知回避性．悪性アプレットが実行するのは，チャネルの Open という一般的な SIM アプレットでも観測される正当な操作のみであり，通常の BIP 利用との区別が難しい．加えて，攻撃者は `TIMER MANAGEMENT` により発火時刻を任意に設定できるため，開発およびテストの段階では無害にふるまい，実運用へ移行した後に占有を開始できる．これにより，静的または動的な検査や事前のテストによる検知を回避できる．第 4 章の PoC 実装では，SIM 挿入から一定時間の経過後に占有を開始する動作を確認する．

3.2 想定シナリオ

本攻撃は，SIM アプレット開発用の OSS ライブラリが普及した環境を前提とする．攻撃者はライブラリ経由で悪性コードを混入させ，正規の開発者が気づかずに取り込み，自社のアプレットとして SIM へ展開する．配布の経路としては，製造工程で悪性アプレットを組み込んだ SIM を大量に出荷する場合のほか，OTA によるアプレット更新を通じて，すでに稼働している多数の SIM へ悪性アプレットを配布する場合も考えられる．いずれの経路でも，時間制御と組み合わせれば，悪性アプレットをインストールした全端末で通信を同時多発的に停止させられる．用途特化の UI をもち検知機構の乏しい IoT 機器では，異常の発見と対処が遅れ，被害が深刻になりやすい．

3.3 影響

SIM アプレットは，決済端末での機微情報処理 [4] や IoT 機器の認証基盤 [3, 16] など，可用性が重視される用途で実運用が広がりつつある．これらの用途に対し，本攻撃は次の影響をもたらす．

直接的な影響．攻撃が成立すると，正規アプレットの `OPEN CHANNEL` が失敗し，SIM を起点とするネットワーク通信が不能となる．ウォレットや決済のアプレット [4] ではサーバとの通信が絶たれて決済が不能となり，IoT 機器では相互認証やデータ送信 [3] が停止する．

持続性．悪性アプレットがチャネルを保持し続ける限り，通信不能の状態は継続する．先行研究のメモリ占有では，揮発性メモリが時間経過で解放されるため周期的な再確保を要したのに対し，BIP チャネルは明示的に閉じない限り解放されない．このため本攻撃は，再確保をともなわずに占有を維持でき，通信不能を容易に永続化できる．

波及性．発火時刻を制御できるため，同一の悪性アプレットを抱える全端末で被害が同時に顕在化しうる．その影響は単一の端末にとどまらず，IoT サービス全体の停止へ波及する可能性がある．BIP を用いた遠隔管理（OTA によるアプレット更新など）も占有されたチャネルを共有するため，BIP 経由の遠隔復旧は妨げられる．復旧には個々の端末への対処が必要となり，大規模な展開では時間とコストの負担が大きい．

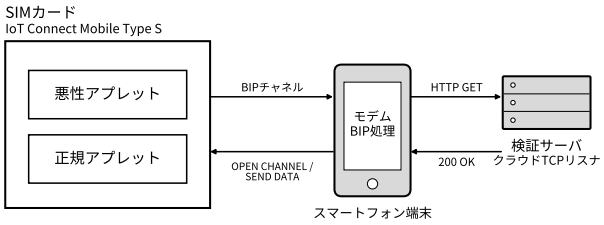


図 2 実験構成

4. 実装と評価

本章では，通信チャネル占有攻撃の PoC を実装し，複数の実機で実現可能性と端末依存性を評価した．

4.1 実験環境

SIM カードには，NTT ドコモビジネスの IoT Connect Mobile Type S を用いた．これはメモリ占有攻撃を示した先行研究 [1] と同一のカードであり，資源占有の対象をメモリからネットワークへ拡張する本研究の比較基盤となる．端末は，モデム系統の異なる 2 機種（端末 A，端末 B）を用いた．実験構成を図 2 に示す．

4.2 BIP チャネルの資源特性

PoC 実装に先立ち，BIP チャネルのネットワーク資源としての性質を確認した．チャネル数の上限や，チャネル状態が他アプレットから見えるかは仕様書だけでは判断できないため，実機を通じて検証した．その結果，次の 2 点が明らかになった．

第一に，同時に開ける BIP チャネル数には上限があり，この上限はアプレットごとではなく端末全体で共有される．Terminal Profile は端末が対応可能な機能を SIM へ申

© 2026 Information Processing Society of Japan

告する仕組みであり，端末全体で利用可能なチャネル数（total）として両端末とも 7 が申告された．ただしこのチャネル数は申告値であり，実行時に実際に開ける本数を保証しない．実際に開ける本数は端末によって異なり，申告値の 7 に満たないこともある（ 4.4 節）．この上限が端末全体で共有されるため，悪性アプレットが占有したチャネル数だけ正規アプレットの確保できるチャネルは減る．これは， 3.1 節で攻撃の成立要件とした BIP チャネルの共有性を，実機で確認した結果にあたる．

第二に，チャネルの状態が複数のアプレット間で共有される．GET CHANNEL STATUS を実行すると，他アプレットが開いたチャネルも含め，開いている全チャネルの ID と確立（up）／切断（down）の状態が取得できた．以上より，あるアプレットが占有したチャネルの存在を，別のアプレットからも観測できる．ただし，この観測可能性は攻撃の成立には必須ではない．チャネルが枯渇していれば，占有状況を観測できなくても正規アプレットの OPEN CHANNEL はエラーで失敗するためである．一方で，この観測可能性は仕様書から自明ではなく本評価で確認した事実であり，防御に利用できる可能性がある．その扱いは第 5 章で述べる．

4.3 PoC 実装

PoC は，サーバとの HTTP 通信を試行する正規アプレットと，全チャネルを占有する悪性アプレットの 2 つのアプレットで構成される．通信先となるサーバは，クラウド上の TCP リスナであり，正規アプレットからの HTTP GET に対して HTTP/1.1 の 200 OK を返す．正規アプレットがこの 200 OK を受け取れるかどうかが，SIM を起点とする通信の成否を表す．両アプレットは，第 3 章で述べたサプライチェーンを介して同一 SIM に導入される状況を想定し，チャネル操作や通信を端末へ要求する手段として ETSI TS 102 223 [8] の Proactive Command のみを用いて，正規のアプレットに許可される操作の範囲内で動作するように実装した．

PoC の動作概要を図 3 に示す．占有前は正規アプレットがサーバと正常に通信でき，悪性アプレットがタイマ満了で全チャネルを占有した占有後は，正規アプレットの通信要求が失敗してサーバへ送信できなくなる．以下に各アプレットの実装を述べる．なお，Proactive Command をともなう詳細なシーケンスは付録の図 A·1 に示す．

正規アプレット．正規アプレットは，STK メニューの user open で OPEN CHANNEL を 1 本開き，HTTP GET の送信から応答判定までを行った後に CLOSE CHANNEL する．チャネルが枯渇していると，この一連の動作は OPEN CHANNEL の段階で失敗し，HTTP GET が送出されないため 200 OK も返らない．このとき正規アプレットは OPEN CHANNEL が返すエラーを表示するので，通信が失敗した事実に加え，

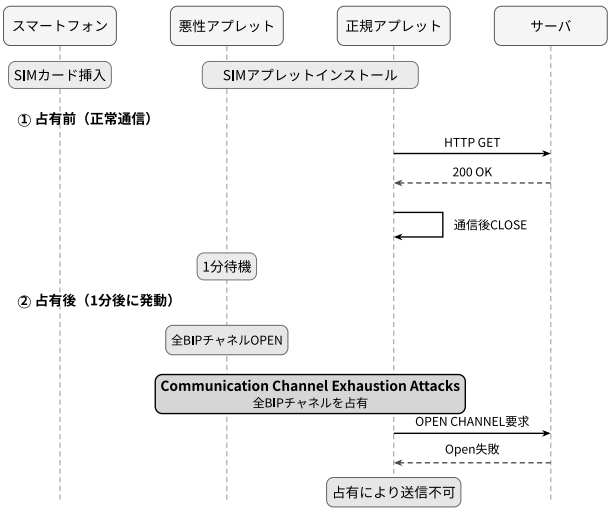


図 3 PoC の動作概要

その原因がチャネルの枯渇であることも確認できる．この設計により，通信自体はサーバへ到達しているのにエラー表示だけが生じる実装上の誤りと，本攻撃による通信不能とを取り違えずに切り分けられる．

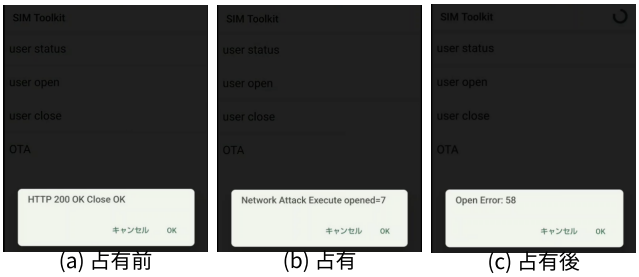
悪性アプレット．悪性アプレットは，SIM 挿入後の EVENT_PROFILE_DOWNLOAD を契機に TIMER MANAGEMENT でタイマを起動する．悪性動作の発火時刻は攻撃者が制御でき，SIM の利用開始から十分に時間が経過した後に発火できる点が攻撃の肝である．本 PoC ではタイマを約 1 分に設定し，設定どおりに発火することを確認した．タイマ満了後は，GET CHANNEL STATUS で得た空きチャネル数を上限に，エラーが返るまで OPEN CHANNEL を繰り返す（取得できない場合は， 4.2 節で述べた上限の 7 を既定値とする）．成功した各チャネルは，攻撃状態を維持するため CLOSE せず保持する．

4.4 検証結果

本節では，正規アプレットの OPEN CHANNEL が失敗し，サーバへ送信できなくなる状態を攻撃の成立と定義する．本攻撃は BIP チャネルの資源管理という決定的な機構に基づくため，実機で成立が確認できれば，その成否は試行回数に依存しない．占有前後の端末画面を図 4 に示す．占有後の画面に表示される「Open Error:58」は，正規アプレットの OPEN CHANNEL が返した Result 値 0x3A（10 進で 58）であり，ETSI TS 102 223 [8] が定める BIP の恒久的なエラーを表す（ 6.1 節）．すなわち，チャネルが枯渇して新たに確保できないことを示している．

端末別の結果．端末 A では全 7 チャネルの占有に成功し，占有後の正規アプレットは 8 本目を開けなかった．この上限は宛先 IP に依存せず，7 チャネルが開いた状態では宛先 IP を変えても新たなチャネルは開けなかった．一方で端末 B では，同時オープンの上限が実質 1 チャネルであった．この場合も，悪性アプレットが取得可能な最大チャネル（1

© 2026 Information Processing Society of Japan



(a) 占有前　(b) 占有　(c) 占有後

図 4　占有前，占有，占有後の端末画面

本）を占有することで正規アプレットの `OPEN CHANNEL` を失敗させられ，攻撃は成立した．

全端末に共通する結果．両端末で攻撃は成立し，差は同時オープン上限（7 チャネルと 1 チャネル）のみである．悪性アプレットが取得可能な最大チャネルを占有すれば，上限値にかかわらず正規アプレットの通信を妨害できる．チャネルを `CLOSE` せず保持することで占有は継続し，正規アプレットの通信不可状態を持続できる．以上より，BIP チャネルの共有性（ 4.2 節）を悪用した通信チャネル占有攻撃が，端末のチャネル数上限によらず実機で成立することを確認した．端末差の要因に関する考察は第 6 章で述べる．

5. 防御手法

本章では，通信チャネル占有攻撃に対する防御を，攻撃の実行時に検知して対処するランタイム防御と，攻撃の前提を断つ導入時防御の二層に分けて検討する．

5.1 攻撃の一般性と防御の前提

第 4 章で示したように，端末 A と端末 B のいずれでも攻撃は成立した．両者の差は同時オープン上限（7 チャネルと 1 チャネル）のみである．上限が 1 チャネルの端末 B でも妨害が成立することから，チャネル数の多寡は本質的な防御にはならない．一方でこの端末差は，後述する事前確保による防御（ 5.3 節）の有効性を左右する．

5.2 ランタイム防御とその限界

ランタイム防御として，チャネル状態の監視と，占有されたチャネルの強制 Close を実機で検証した．

チャネル状態の監視．`GET CHANNEL STATUS` により，正規アプレットは他アプレットが開いたチャネルも観測できる．悪性アプレットが占有した 7 チャネルを正規アプレット側から確認でき，各チャネルが link established 状態であることも取得できた．したがって，占有の発生自体は検知できる．ただし Channel Status を構成する TLV には所有者（AID 相当）を示すフィールドがなく，どのアプレットが占有しているかを特定できない．このため検知は開いているチャネル数の閾値超過に限定され，対処すべきアプレットを絞り込めない．また，端末側からチャネル占有を観測する手段も限られる．BIP チャネルは UICC と端末の間で確立され，輸送層の処理と外部への送出は端末側が担う [8]．このため BIP による送出は，アプリケーションの外向き通信として OS が扱う経路を経由しないと考えられる．実際，root 権限を用いない一般的な VPN 型の監視ツールでは，占有にともなう通信を捕捉できなかった [17]．結果として占有を把握できるのは事実上 SIM アプレット側に限られるが，その観測をもってしても，次に述べるように占有されたチャネルを解放することはできない．

強制 Close によるチャネル解放．チャネルが解放されれば通信妨害は解消する．悪性アプレットが自ら Close した後は，正規アプレットが `SEND DATA` から HTTP 200 OK，`CLOSE CHANNEL` まで完了し，通信が回復することを確認した．しかし正規アプレットは悪性アプレットのチャネルを Close できない．他アプレットが開いたチャネルに対する `CLOSE CHANNEL` は `ToolkitException`（code `0x0F`, `COMMAND_NOT_ALLOWED`）となり，Close できるのは自身が開いたチャネルに限られる．このため悪性アプレットによって Open されたチャネルの強制 Close は成立しなかった．

監視は占有元を特定できず，強制 Close は他アプレットのチャネルに及ばない．いずれも自身が開いたチャネルしか制御できないという現行実装の制約に阻まれ，ランタイムでの直接的な対処は難しい．

5.3 制約を逆用した防御：監視用チャネルの事前確保

5.2 節での「自身のチャネルは他アプレットに奪われない」という制約は，裏を返せば防御に利用できる．そこで，正規アプレットまたは監視専用アプレットが起動時にチャネルを事前確保する手法を提案する．起動時に 1 チャネルを確保しておけば，全体が占有されてもアラート送信や OTA 更新の経路を維持でき，最低限の通信路を確保できる．ただし，この手法が成立するには，監視用アプレットが悪性アプレットより先に起動する必要がある．UICC API では，同一イベントに登録された Toolkit アプレットはインストール時に設定される優先度に従って起動される [18]．この優先度は Toolkit Application Specific Parameters として指定される [19]．よって，発行者が監視用アプレットに高い優先度を与え，第三者アプレットにはそれ以下の優先度しか認めない運用を行えれば，事前確保は緩和策となる．一方で，本評価で用いた SIM において優先度指定が実際に利用可能かは未検証であり，優先度を管理できない環境ではこの手法は確実な防御にならない．また悪性アプレットが確保できるのは残りの空きチャネルに限られる．特に上限が 1 チャネルの端末 B では，正規アプレットが起動時にそのチャネルを確保さえすれば攻撃の成立を完全に防げる．一方で上限が 7 チャネルの端末 A では，事前確保しない正規アプレットは依然として妨害され得る．すべてのアプレットが確保すれば正当な用途でチャネルが枯渇す

© 2026 Information Processing Society of Japan

るため，事前確保は監視や緊急通信用の最小限にとどめるべきである．

5.4 導入時防御：ロード時トークン検証

監視用チャネルの事前確保は最低限の通信確保にとどまり，攻撃そのものは阻止できない．したがって，攻撃の前提である悪性アプレットの導入を，ロード時に断つ対策を検討する．GlobalPlatform Card Specification は，アプレットのロードが正当に認可されていることをカード上で検証する署名データとして，Load Token を規定している [20]．Load Token は，ロードされるコード本体の完全性を検証する DAP（Data Authentication Pattern）とは役割が異なり，そのコードを特定の AID や Security Domain，ロード条件でロードしてよいかという操作の認可を検証する．Load File Data Block Hash や対象 AID などを発行者が署名し，ロード時に SIM 上の Security Domain がその存在と正当性を確認する．この検証を必須とすれば，Secure Channel の鍵を持つ主体であっても，発行者が承認していないアプレットや条件ではロードできなくなる．

本攻撃はサプライチェーン経由で悪性アプレットを新たに SIM へ導入することで成立するため，発行者を介さないアプレットの導入を防ぐ Load Token は，本攻撃への対策として意味を持つ．ただし，Load Token が検証するのはロードの認可であって，コードそのものの安全性ではない．本研究が想定するサプライチェーン攻撃では，悪性コードが OSS ライブラリに潜んで正規のアプレットに取り込まれるため，発行者がこれを見抜けずに承認し，署名してしまえば，正当な Load Token が付与され，ロードを阻止できない．したがって Load Token の有効性は，承認の段階で悪性コードを検知できるかに依存し，署名鍵が漏洩した場合にも同様に破られる．

また，導入面では課題が残る．GlobalPlatform の Card Content Management 機能は Java Card OS に実装例が見られるものの，MNO や SIM ベンダが実運用で有効化しているという公開情報は確認できていない．Load Token の必須化は，DAP 鍵や Token 鍵の管理，OTA 配信フローの複雑化といった運用負荷もともなう．

いずれの対策にも限界があり，署名前に悪性コードを検知するという根本の課題は依然として残る．

6. 議論

6.1 制約事項

本研究は，攻撃の成立に必要な二つの条件を実機で確認した．一つは BIP チャネルが複数のアプレット間で共有され，占有によって枯渇すること（ 4.2 節），もう一つは悪性アプレットを正規の開発と配布プロセスを通じて同一 SIM へ導入できること（第 4 章）である．これらは特殊な環境ではなく，アプレット領域分割技術による第三者開発が広がる標準的な環境で満たされうる．一方で，評価は 2 機種の端末と 1 種類の SIM カードに限定される．端末やカードの違いによる差異を一般化するには，より多様なモデムおよび SIM での検証が必要であり，これは今後の課題である．

端末差．第 4 章では，同時に確保できるチャネル数が端末 A で 7 本，端末 B で実質 1 本と異なった．この差は，モデム系統の違い，すなわちモデムまたは Radio Interface Layer（RIL）の実装に起因すると考えられる．実際，端末 B では 2 本目以降の `OPEN CHANNEL` が `3A00` に集約される．このエラーは ETSI TS 102 223 [8] が定める Result 値であり，`3A` は Bearer Independent Protocol の恒久的なエラーを，`00` は具体的な原因が示されないことを表す．失敗が一律に原因不明のこのエラーへ収束することからも，制限の要因は SIM 側ではなく端末側にある可能性が高い．ただし，上限が 1 本であっても悪性アプレットがその最大値を占有すれば攻撃は成立するため，端末差は攻撃の成否を左右せず，本攻撃が端末に依存しない汎用的な脅威であること（ 3.1 節）を裏づける．しかし，1 本に制限される要因そのものは特定できていないため，端末側ログの検査を通じた切り分けを今後進める．

防御．ランタイム対策には自身が開いたチャネルしか制御できないという構造的な制約があり（ 5.2 節），ロード時トークン検証（ 5.4 節）は方式の提案にとどまる．また，実機での実装と評価は今後の課題である．

今後は，ネットワーク占有とメモリ占有を包含した悪性アプレットに起因する脅威モデルを整理し，設計段階から悪性アプレットによる脅威を防ぐセキュリティバイデザインに基づく対策へつなげることを目指す．

7. 結論

本研究では，SIM アプレット領域分割技術による第三者開発の広がりを背景に，サプライチェーンを起点とし悪性 SIM アプレットが BIP チャネルを占有し，同一 SIM 上の正規アプレットの通信を妨害する通信チャネル占有攻撃を提案した．本攻撃は，標準化された Proactive Command のみを用い，Java Card OS の脆弱性や物理攻撃に依存しない，アプリケーションレベルの資源枯渇型 DoS である．

PoC を実装し，モデム系統の異なる 2 機種の実機で評価した結果，いずれの端末でも悪性アプレットが取得可能な最大のチャネルを占有することで正規アプレットの通信を遮断でき，攻撃が成立することを確認した．同時に確保できるチャネル数は端末によって異なるが，その多寡は攻撃の成否を左右せず，本攻撃が特定の端末実装に依存しないことを示した．あわせて，`GET CHANNEL STATUS` によってチャネルの状態がアプレット間で共有されるという，攻撃の前提となる知見を得た．

防御については，チャネル状態の監視や強制 Close と

© 2026 Information Processing Society of Japan

いったランタイム対策には，自身が開いたチャネルしか制御できないという構造的な限界があることを示した．その制約を逆用した監視用チャネルの事前確保が緩和策となること，および攻撃の前提を断つには導入時の検証が要点となるが，署名済みの悪性コードには及ばないことを示した．

本研究は，先行研究のメモリ占有に続き，ネットワーク資源が SIM アプレットによる資源占有型攻撃の新たな標的となることを明らかにした．この知見は，第三者開発が広がる SIM アプレットにおいて，設計段階から資源占有を抑止するセキュリティバイデザインの必要性を示すものである．

参考文献

[1] 迫本澪, 渡邉龍星, and 松木隆宏. 悪性 sim アプレットによるメモリ占有攻撃の評価と防御. **電子情報通信学会技術研究報告（信学技報）**, 124(422):297–305, 3 2025. ICSS2024-107.

[2] IoT Analytics. Number of connected IoT devices growing 14% to 21.1 billion. State of IoT 2025, 2025. accessed 2026-08-10.

[3] GSMA. IoT SAFE: SIM Applet For Secure End-2-End Communication, 2021. accessed 2026-08-10.

[4] NTT ドコモビジネス株式会社. 「アプレット領域分割技術」を活用した ntt com の sim が非対面決済向けクラウド型決済端末でトップシェアのアイティアクセスのクラウド型決済端末に採用. 報道発表, 4 2024. accessed 2026-08-10.

[5] Andres Freund. backdoor in upstream xz/liblzma leading to ssh server compromise. oss-security mailing list, 2024. accessed 2026-08-10.

[6] npm, Inc. Details about the event-stream incident. npm Blog, 2018. accessed 2026-08-10.

[7] AdaptiveMobile Security. Simjacker: Next generation spying over mobile. Technical Report, 2019. accessed 2026-08-10.

[8] ETSI. Smart cards; card application toolkit (cat) (release 18). Technical Specification ETSI TS 102 223 V18.2.0, European Telecommunications Standards Institute, April 2025. accessed 2026-08-10.

[9] Jinghao Zhao, Boyan Ding, Yunqi Guo, Zhaowei Tan, and Songwu Lu. SecureSIM: Rethinking authentication and access control for SIM/eSIM. In *Proc. 27th Annual International Conference on Mobile Computing and Networking (MobiCom)*, pages 451–464, 2021.

[10] 松田奈々, 渡邉龍星, 松木隆宏, and 小林信博. Sim スワップ攻撃対策を考慮した効率的な機器変更手法の提案. **コンピュータセキュリティシンポジウム** *2024* **論文集**, pages 1572–1578, 2024.

[11] Guillaume Barbu, Hugues Thiebeauld, and Vincent Guerin. Attacks on Java Card 3.0 combining fault and logical attacks. In *Smart Card Research and Advanced Applications (CARDIS 2010)*, pages 148–163. Springer, 2010.

[12] Guillaume Barbu, Guillaume Duc, and Philippe Hoogvorst. Java Card operand stack: Fault attacks, combined attacks and countermeasures. In *Smart Card Research and Advanced Applications (CARDIS 2011)*, pages 297–313. Springer, 2011.

[13] Guillaume Barbu, Christophe Giraud, and Vincent Guerin. Embedded eavesdropping on Java Card. In *Information Security and Privacy Research (IFIP SEC 2012)*, pages 37–48. Springer, 2012.

[14] Julien Lancia. Java Card combined attacks with localization-agnostic fault injection. In *Smart Card Research and Advanced Applications (CARDIS 2012)*, pages 31–45. Springer, 2012.

[15] Guillaume Bouffard, Jean-Louis Lanet, Jean-Baptiste Machemie, Jean-Yves Poichotte, and Jean-Philippe Wary. Evaluation of the ability to transform SIM applications into hostile applications. In *Smart Card Research and Advanced Applications (CARDIS 2011)*, volume 7079 of *LNCS*, pages 1–17. Springer, 2011.

[16] Trusted Connectivity Alliance. Iot safe: Making the iot scalable, simpler and safer. Technical report, Trusted Connectivity Alliance, December 2019. accessed 2026-08-10.

[17] 古橋俊輝, 迫本 澪, 橋本 明将, and 干川 尚人. Sim アプレットを悪用した親密圏監視と端末中心防御の限界. In **コンピュータセキュリティシンポジウム** *2026* **論文集**, 2026. 発表予定.

[18] ETSI. Smart cards; uicc application programming interface (uicc api) for java card (release 18). Technical Specification ETSI TS 102 241 V18.1.0, European Telecommunications Standards Institute, April 2024. accessed 2026-08-16.

[19] ETSI. Smart cards; remote apdu structure for uicc based applications (release 16). Technical Specification ETSI TS 102 226 V16.0.0, European Telecommunications Standards Institute, November 2021. accessed 2026-08-16.

[20] GlobalPlatform. Card specification, version 2.3.1. Technical Report GPC_SPE_034, GlobalPlatform, 3 2018. accessed 2026-08-10.

© 2026 Information Processing Society of Japan

研究倫理

本研究が指摘する脅威は，特定の SIM カードや端末の脆弱性ではなく，端末側で共有される有限資源である BIP チャネルの管理機構と，複数の第三者アプレットを同一 SIM に同居させる SIM アプレット領域分割技術の組み合わせに起因するものである．また，本研究で想定する攻撃シナリオは，SIM アプレット開発用のオープンソースライブラリが普及した環境を前提としている．現時点では，そのようなライブラリの公開事例は限定的であり，直ちに攻撃が実現される可能性は低い．しかし，技術の発展に伴い OSS の活用が進むことが予想されることから，本研究の知見を事前に共有し，SIM カードのセキュリティ向上に寄与することを目的として公開するものである．

付　　録

A.1　PoC 実装の詳細

本付録では，4.3 節で述べた PoC の各アプレットの実装の詳細なシーケンス（図 A·1）を示す．

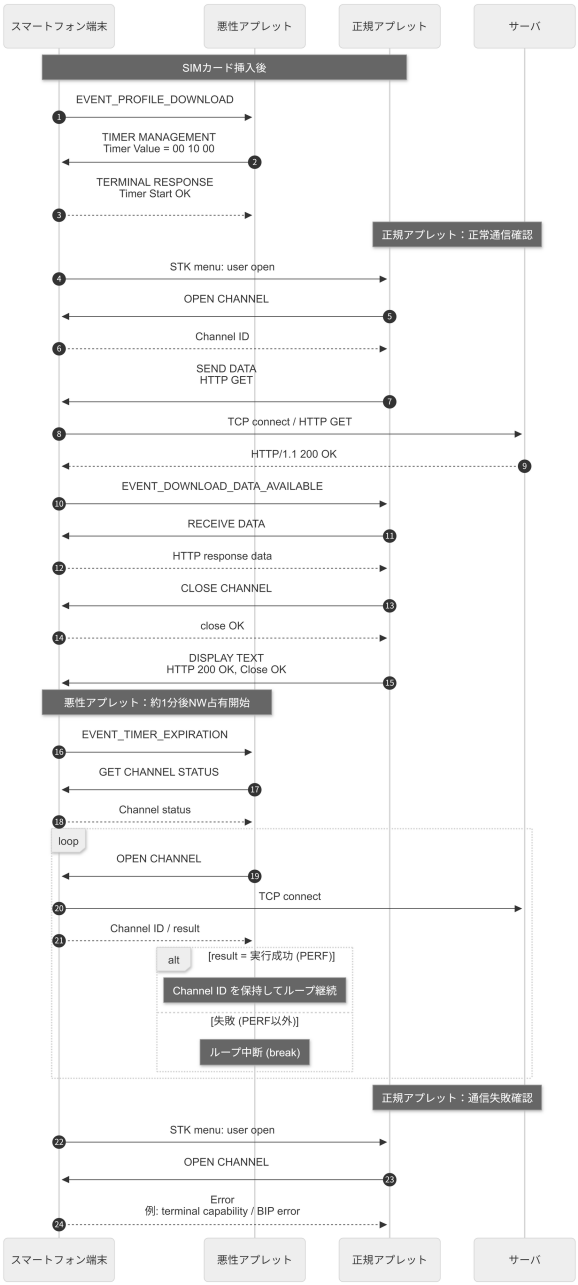


図 A·1　PoC の詳細シーケンス

© 2026 Information Processing Society of Japan